PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Pilotage de la cybersécurité pour dirigeants

03-710 Cybermalveillance et Bpifrance - Guide de cybersécurité des dirigeants de TPE, PME et ETI — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La transformation numérique augmente la surface d'attaque et les sous-traitants constituent souvent un maillon faible pour atteindre un grand groupe.
2. La cyber-hygiène repose sur 6 règles incluant les mots de passe, les mises à jour, les sauvegardes déconnectées et l'authentification multifacteur.
3. En cas d'attaque, il faut déconnecter les équipements infectés du réseau sans les éteindre ni les redémarrer pour préserver les traces.

Enjeux de la cybersécurité

Notion	À retenir
Cibles mal protégées	La transformation numérique (**cloud**, **IoT**, **5G**) augmente la surface d'attaque. Les **sous-traitants** sont souvent le maillon faible pour atteindre un grand groupe.
Freins des dirigeants	1. Connaissance **superficielle** du risque. 2. Manque de solutions **clés en main**. 3. **Coût perçu** (pourtant la cyber-hygiène est simple et peu onéreuse).
Valeurs à protéger	**Financière** (perte CA, frais), **réputationnelle** (RGPD/CNIL), **intangible** (R&D, clients), **humaine** (stress, chômage technique) et **création de valeur** (argument commercial).

Répartition des demandes d'assistance

22 % rançongiciels	**20 %** intrusions
14 % piratage de compte	**10 %** usurpation d'identité
8 % hameçonnage	**5 %** déni de service
4 % fraude au virement	**2 %** défiguration

Menaces et parades

Attaque	Parade / Mesure
Piratage de compte	L'**authentification multifacteur**
Déni de service	Solutions techniques (**paramétrage du serveur**, **captcha**, **limitation des connexions** et **offre anti-DDoS de l'hébergeur**)
Faux changement de RIB	Fraude au virement : changement de RIB ou **fraude au président**. Seule parade efficace : **appeler directement le fournisseur** avec des coordonnées fiables ; jamais de virement dans l'urgence.
Hameçonnage	Pas une attaque en soi mais le **vecteur** d'attaques ultérieures (piratage, intrusion, fraude au virement, rançongiciel).

Prévention et préparation

Notion	À retenir
Culture d'entreprise	Le dirigeant et le **comité de direction** incarnent la culture. Il faut interroger les **fournisseurs/prestataires** et nommer un **référent cybersécurité** au comité de direction.
Cyber-hygiène	**6 règles** : mots de passe (longs, complexes, coffre-fort), sensibilisation (charte, formation), mises à jour (registre, **2 éditeurs antivirus**), éviter risques (USB, réseaux publics), sauvegardes (déconnectées, testées) et garde-fous (VPN, **authentification multifacteur**).
Se préparer au pire	Préparation en **3 étapes** : **diagnostic**, **plan d'action**, **plan de continuité d'activité**. Outils : **Diag Cybersécurité** (4 jours), **Autodiag** gratuit ou **Diagnostic Cyber Défense** (DGA).

Piloter sa cybersécurité en dix étapes

1. État des lieux des **actifs numériques** et de leurs responsables
2. Évaluer la **criticité** de chaque système
3. Évaluer son **niveau de protection**
4. **Plan d'action** priorisé (criticité, coût, efficacité) : **80 %** des attaques évitables par des mesures simples
5. Se faire accompagner (**référent**, prestataire)
6. **Sensibiliser** les collaborateurs
7. Se préparer au pire (plans de secours, annuaire de crise, exercices)
8. S'impliquer et **montrer l'exemple**
9. Contrôler par des **audits**
10. **Itérer** pour tout nouveau système et tous les 2 à 3 ans

Réagir à une cyberattaque

Notion	À retenir
Sécuriser	Mettre en sécurité les **personnes** (si équipements industriels), **déconnecter** du réseau/Internet les équipements infectés. **Ne pas éteindre** ni redémarrer pour préserver les traces. **Ne pas payer** la rançon.
Alerter	Alerter **collaborateurs**, **support**, **banque**, **assureur**. **Déposer plainte** avant remédiation. Notifier **CNIL** sous **72 heures** si données personnelles exposées. Informer **ANSSI** (OIV, OSE, FSN).
Remédier et reprendre	Déclencher le **plan de continuité**. Identifier **origine** et **étendue** avant reprise. Remise en service **progressive sous surveillance**. Tirer les enseignements et gérer les **risques psychologiques**.
Consignes aux collaborateurs	**Débrancher** du réseau, **ne pas éteindre**, alerter le **support informatique**, ne plus utiliser l'équipement et **prévenir ses collègues**.

Pièges et confusions

- ⚠ Croire qu'une assurance de responsabilité civile couvre les frais propres de l'entreprise sans garantie cyber spécifique.
- ⚠ Remettre en production sans connaître l'origine de l'attaque, au risque d'une réplique.
- ⚠ Entamer la remédiation avant le dépôt de plainte, ce qui empêche de préserver les preuves.
- ⚠ Ignorer que les cybercriminels partagent entre eux les vulnérabilités non corrigées des victimes.

Sigles et définitions

cyber-hygiène : ensemble des bonnes pratiques simples que les collaborateurs observent pour limiter le risque d'attaque et de fuite d'information

ingénierie sociale : techniques de manipulation qui exploitent la peur, la confiance, la curiosité, l'appât du gain et les relations hiérarchiques

bruit cyber : cybercriminalité de masse, faite d'attaques non ciblées diffusées à grande échelle

surface d'attaque : ensemble des portes d'entrée qu'une entreprise offre aux cybercriminels

cyber-résilience : capacité à maintenir une activité même dégradée après une attaque et à se rétablir rapidement

plan d'assurance sécurité : document par lequel un prestataire décrit comment il protège les données de son client

label ExpertCyber : label valorisant les prestataires en sécurité numérique compétents et transparents

Auto-test

1. Quel pourcentage des cyberattaques pourrait être évité par des mesures simples ?
2. Quel est le délai pour notifier la CNIL en cas d'exposition de données personnelles ?
3. Quelle mesure technique permet de contrer une attaque par piratage de compte ?
4. Quelle est la première étape de la préparation en cas de pire scénario ?
5. Que faut-il faire face à une demande de changement de RIB suspecte ?

Réponses : **1.** 80 pour cent · **2.** 72 heures · **3.** L'authentification multifacteur · **4.** Le diagnostic · **5.** Appeler directement le fournisseur avec des coordonnées fiables

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.